

A.U. Securities
Technology Risk & Controls Assessment
Audit Findings Report

Prepared for Educational/Portfolio Purposes

August 2026

1. Purpose and Scope

This report summarizes the key control findings identified during a simulated technology risk and controls assessment of A.U. Securities, a fictional online brokerage platform. The assessment focused on technology and operational risks related to customer authentication, privileged access, transaction processing, security monitoring, third-party services, business continuity, and other critical brokerage activities.

The findings in this report were developed from the project risk register and risk and control matrix. Each finding describes an identified control weakness, the potential business impact, and a recommended action to reduce the associated risk.

2. Audit Findings

The following findings represent the most significant control weaknesses identified during the assessment and are prioritized based on their potential impact on customer assets, brokerage operations, and system security.

Finding 1 — Step-Up Authentication Is Not Consistently Required for High-Risk Customer Actions

Risk Rating: Critical

Related Risks: R-001 — Identity & Access Management; R-002 — Transaction & Fraud Controls

Observation

A.U. Securities requires MFA for customer login and uses controls such as bank ownership verification and customer notifications for changes to linked bank accounts. However, additional authentication is not consistently required before certain high-risk account actions, including adding a new external bank account or making other sensitive account changes. Withdrawals may also be permitted shortly after a bank-account change.

Risk

If a customer account is compromised, an unauthorized user could make high-risk account changes, add a bank account under their control, and attempt to withdraw customer funds. This could result in customer financial loss, reimbursement costs, complaints, and reputational damage to the brokerage.

Recommendation

Require step-up MFA or additional identity verification before high-risk account changes are completed. Bank ownership should be verified before a new external account becomes eligible for withdrawals, and temporary withdrawal restrictions or additional review should be considered following higher-risk account changes.

Finding 2 — Privileged Access Reviews Are Not Performed Consistently

Risk Rating: High

Related Risk: R-003 — Identity & Access Management

Observation

A.U. Securities uses role-based access controls, manager approval, and account deactivation procedures to manage employee and administrator access. However, periodic access reviews are not performed consistently, which may allow employees who change roles or leave the organization to retain permissions they no longer need.

Risk

Excessive or outdated access increases the chance that sensitive customer information, administrative functions, or brokerage systems could be accessed or changed by unauthorized personnel. This could lead to data exposure, unauthorized account changes, fraud, or misuse of privileged functions.

Recommendation

Perform formal access reviews on a consistent schedule, such as quarterly, for systems containing sensitive customer or brokerage information. Access should be reviewed against current job responsibilities, unnecessary permissions should be removed and terminated-user access should be disabled promptly.

Finding 3 — Security Logging and Alert Review Are Inconsistent

Risk Rating: High

Related Risk: R-004 — Logging & Monitoring

Observation

A.U. Securities uses centralized security logging and automated alerts to monitor authentication, administrative, and brokerage activity. However, logging coverage is not consistent across all critical systems, and high-risk alerts are not always reviewed within a defined timeframe.

Risk

Incomplete logging or delayed alert review can make it harder to detect account compromise, employee misuse, fraudulent activity, or other security incidents. Delayed detection may allow suspicious activity to continue longer before it is investigated and contained.

Recommendation

Ensure critical brokerage systems consistently send relevant security logs to the centralized monitoring platform. Define documented review and escalation timeframes for high-risk alerts and periodically confirm that important log sources remain connected and active.

Finding 4 — Disaster Recovery Testing Does Not Fully Cover Critical Brokerage Operations

Risk Rating: High

Related Risk: R-009 — Business Continuity & Resilience

Observation

A.U. Securities maintains backups, redundant infrastructure, and a disaster recovery environment to support critical systems. However, disaster recovery testing is not performed consistently and does not always include the full set of brokerage processes, customer data, and third-party dependencies needed to support recovery.

Risk

If a major outage, system failure, or cyber incident occurs, the company may not be able to restore critical services within expected recovery targets. This could prevent customers from accessing accounts or completing transactions and may lead to data loss, operational disruption, and customer complaints.

Recommendation

Perform disaster recovery testing on a defined schedule and include the systems, data, and third-party services that support critical brokerage activity. Test results should confirm whether recovery time and recovery point objectives were met, and any failures or delays should be documented and addressed.

Finding 5 — High-Risk Vulnerabilities Are Not Consistently Escalated

Risk Rating: High

Related Risk: R-011 — Vulnerability & Patch Management

Observation

A.U. Securities performs vulnerability scanning and tracks remediation based on severity. However, overdue High and Critical vulnerabilities are not consistently escalated when remediation deadlines are missed, and formal risk acceptance is not always documented.

Risk

Unresolved high-risk vulnerabilities may remain exposed longer than intended, increasing the chance of unauthorized access, system compromise, data exposure, or service disruption. Without clear escalation and risk acceptance, management may also lack visibility into vulnerabilities that remain open beyond required timelines.

Recommendation

Establish a formal escalation process for overdue High and Critical vulnerabilities. Remediation deadlines should be tracked, overdue items should be reported to management, and any decision to delay remediation should include documented risk acceptance and an expected resolution date.

3. Findings Summary

#	Finding	Risk Rating
1	Step-Up Authentication Is Not Consistently Required for High-Risk Customer Actions	Critical
2	Privileged Access Reviews Are Not Performed Consistently	High
3	Security Logging and Alert Review Are Inconsistent	High
4	Disaster Recovery Testing Does Not Fully Cover Critical Brokerage Operations	High
5	High-Risk Vulnerabilities Are Not Consistently Escalated	High

The Critical finding represents two related Critical risks, R-001 and R-002, which were consolidated because they share the same underlying step-up authentication weakness. This report presents one Critical and four High-rated findings. The most significant concern relates to controls over high-risk customer account changes because weaknesses in additional authentication could increase the risk of unauthorized account activity and withdrawals. The remaining findings primarily relate to access governance, security monitoring, operational resilience, and vulnerability management.